

Chapitre 11

La maîtrise du risque d'externalisation

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — Les cinq catégories de risque et la non-transférabilité de la responsabilité

- (a) Le cours identifie cinq catégories de risque associées au recours à un prestataire : le risque de **conformité** (« lorsque les services d'un prestataire enfreignent les lois ou règlements applicables »), le risque de **concentration** (« lorsque des services externalisés sont fournis par un nombre limité de prestataires ou concentrés sur une zone géographique restreinte »), le risque **réputationnel** (« actions ou contre-performances du prestataire qui ternissent l'image de l'établissement »), le risque **pays** (« dès lors que le prestataire est situé à l'étranger ») et le risque **opérationnel** (« processus ou systèmes internes défaillants chez le prestataire, ou événements externes et erreurs humaines »). Pour chacune de ces cinq catégories, donner un exemple concret et distinct d'un incident qui l'illustrerait, en veillant à ce que chaque exemple ne puisse raisonnablement être rattaché qu'à une seule des cinq catégories.
- (b) Le cours affirme que « recourir à un prestataire ne dispense en rien le conseil d'administration et la direction générale de leur responsabilité de s'assurer que l'activité externalisée est conduite de manière saine et conforme à la réglementation » et ajoute : « cette responsabilité, contrairement à l'activité elle-même, ne se sous-traite pas ». Expliquer précisément la distinction que cette dernière phrase établit entre l'« activité » et la « responsabilité ». Un établissement qui externaliserait entièrement une fonction, y compris sa supervision quotidienne, pourrait-il, selon cette logique, se prévaloir d'une défaillance du prestataire pour dégager sa propre responsabilité envers ses clients ou son régulateur ?
- (c) Le cours identifie six éléments centraux d'un programme efficace : « l'évaluation des risques de l'activité envisagée; la diligence raisonnable et la sélection du prestataire; les clauses contractuelles; la revue des incitations de rémunération intégrées au contrat; la surveillance continue du prestataire; et la planification de la continuité d'activité en cas de défaillance du prestataire ». Énumérer ces six piliers dans l'ordre chronologique naturel d'une relation d'externalisation, de l'avant-contrat jusqu'à l'après-défaillance éventuelle. Pourquoi un dispositif qui ne comprendrait, par exemple, que les trois premiers piliers (évaluation, diligence, contrat) et négligerait les trois derniers (rémunération, surveillance, continuité) resterait-il incomplet au sens du cours ?
- (d) Le cours précise que « l'ampleur du dispositif doit être proportionnée à la criticité, à la complexité et au nombre d'activités externalisées » et illustre ce principe en opposant « un établissement de petite taille recourant à quelques prestataires réputés pour des fonctions critiques », qui « peut se contenter d'un dispositif plus simple », à « un établissement s'appuyant sur des centaines de prestataires pour des activités à risque matériel », qui « devra mobiliser un dispositif nettement plus riche ». Ce principe de proportionnalité s'applique-t-il, selon vous, à chacun des six piliers identifiés en (c) de façon uniforme, ou certains piliers (par exemple la diligence raisonnable) supportent-ils moins bien une simplification que d'autres (par exemple la revue des incitations de rémunération), y compris pour un établissement de petite taille ? Justifier à partir de la nature de chaque pilier.

Exercice 2 — La diligence raisonnable et les clauses contractuelles

- (a) Avant d'engager un prestataire, le cours exige l'examen de trois axes : « sa réputation et sa stratégie d'affaires, sa situation financière, et ses contrôles internes et opérationnels — y compris, le cas échéant, sa propre diligence sur ses sous-traitants (le « risque de quatrième partie ») ». Expliquer précisément ce qu'est le « risque de quatrième partie » et pourquoi il ne peut être capturé ni par l'examen de la réputation du prestataire, ni par l'examen de sa seule situation financière, mais seulement par l'examen de ses contrôles internes et opérationnels.
- (b) Le cours détaille ce qu'inclut la revue financière du prestataire : « les états financiers récents, la solidité du capital, la liquidité, les résultats d'exploitation, la pérennité de l'activité (ancienneté, croissance de part de marché), l'adéquation de la couverture d'assurance, et l'engagement du

prestataire — en ressources financières et humaines — à honorer le contrat sur toute sa durée ». Parmi ces éléments, lesquels renseignent sur la capacité du prestataire à honorer le contrat *aujourd'hui*, et lesquels renseignent plutôt sur sa capacité à l'honorer *dans la durée*? Justifier la distinction élément par élément.

- (c) Le cours énumère ce qu'un contrat bien conçu doit prévoir : « le périmètre des responsabilités de chaque partie, les modalités de coût et de rémunération, un droit d'audit, des normes de performance mesurables, des exigences de confidentialité et de sécurité de l'information, les conditions de propriété et de licence des données et logiciels, une clause d'indemnisation, les conditions de défaut et de résiliation, un mécanisme de résolution des différends, des exigences d'assurance, et un plan de continuité d'activité du prestataire lui-même ». Parmi ces onze éléments, identifier ceux qui protègent principalement l'établissement en cours d'exécution normale du contrat, et ceux qui ne prennent toute leur importance qu'en cas de dégradation ou de rupture de la relation. Le « droit d'audit » relève-t-il, selon vous, de la première catégorie, de la seconde, ou des deux à la fois?
- (d) Le cours précise que si le prestataire traite des informations personnelles non publiques (NPPI) des clients, « la sécurité, la conservation et l'accès à ces données doivent être explicitement traités dans le contrat — la responsabilité de leur divulgation incombant conjointement à l'établissement et à son prestataire ». Par ailleurs, pour un prestataire situé à l'étranger, « un contrat [...] devrait désigner explicitement la juridiction applicable en cas de litige, afin d'éviter qu'un tribunal étranger n'interprète le contrat selon un droit local potentiellement moins protecteur », les banques américaines restant en outre « tenues de respecter l'ensemble de leur réglementation nationale, même lorsque le prestataire opère depuis l'étranger ». Montrer que ces deux clauses (responsabilité conjointe sur les NPPI, juridiction applicable) répondent à un même risque structurel lorsqu'elles sont combinées pour un prestataire étranger traitant des données NPPI : pourquoi l'absence de désignation explicite de la juridiction applicable aggraverait-elle spécifiquement la portée de la responsabilité conjointe en cas de violation de données?

Exercice 3 — La surveillance continue et la planification de la continuité d'activité

- (a) Le cours exige que l'établissement « fixe des indicateurs de performance mesurables et adapte la fréquence de sa surveillance au niveau de risque du prestataire : plus fréquente et plus stricte pour les prestataires à risque élevé ou montrant des signes de difficulté financière ou de non-conformité, allégée pour les prestataires à faible risque », des « déclencheurs d'escalade » devant « permettre de remonter rapidement tout signal de dégradation vers la direction ». Distinguer précisément le rôle des « indicateurs de performance mesurables » de celui des « déclencheurs d'escalade » : le premier mesure-t-il la même chose que ce que déclenche le second, ou s'agit-il de deux dispositifs aux fonctions distinctes? Pourquoi un indicateur de performance mesurable, à lui seul, sans déclencheur d'escalade associé, resterait-il insuffisant selon la logique du cours?
- (b) Le cours prévoit que « le plan de continuité doit prévoir la sauvegarde des informations, l'articulation avec le propre plan de reprise après sinistre de l'établissement, des tests périodiques, et une stratégie de sortie incluant un vivier de prestataires alternatifs comparables au cas où le prestataire retenu ne pourrait plus assurer le service ». Parmi ces quatre composantes, laquelle suppose que l'établissement ait déjà, en amont et indépendamment de toute défaillance du prestataire, identifié et évalué d'autres prestataires potentiels? En quoi cette composante particulière rend-elle le plan de continuité coûteux à maintenir même en l'absence de toute défaillance effective?
- (c) Le cours précise que « pour les relations les plus significatives, l'établissement doit évaluer la qualité du dispositif de contrôle du prestataire — par exemple via un rapport d'audit type SOC 2 — et intégrer les incidents de sécurité survenus chez le prestataire à sa propre surveillance », ajoutant qu'« aucun contrat, aussi bien rédigé soit-il, ne remplace une vérification active et continue ». En quoi cette dernière affirmation relativise-t-elle la portée du droit d'audit contractuel identifié à l'exercice 2 (c) : un contrat prévoyant un droit d'audit, mais jamais effectivement exercé, satisferait-il à l'exigence de ce chapitre?

- (d) La synthèse du chapitre affirme que « l’externalisation ne transfère jamais la responsabilité ultime d’une activité — seulement son exécution quotidienne » et résume la gestion de ce risque en quatre temps : « évaluer le risque en amont, exercer une diligence raisonnable rigoureuse sur le prestataire pressenti, négocier un contrat qui couvre explicitement la performance, la sécurité, l’audit et la sortie, puis surveiller la relation dans la durée avec une intensité proportionnée au risque, tout en préparant activement le scénario où le prestataire ne pourrait plus honorer ses engagements ». Montrer que chacun des six piliers identifiés à l’exercice 1 (c) trouve sa place dans cette synthèse en quatre temps, et identifier lequel des six piliers ne semble correspondre explicitement à aucun des quatre temps cités — avant de proposer où il s’y rattache implicitement.

2 Exercice cumulatif (chapitres 11, 10, 9, 8, 7)

Exercice 4 — Le risque d’externalisation à la lumière des quatre chapitres précédents

- (a) Le chapitre 10 rapporte que, dans le cas USAA, « le département conformité LCB-FT était “significativement sous-effectif”, comblé par des sous-traitants dont les qualifications n’avaient pas été vérifiées », une défaillance ayant contribué à une sanction de 140 millions USD pour n’avoir pas mis en œuvre un programme de conformité conforme aux exigences minimales du Bank Secrecy Act — le régulateur ayant sanctionné, selon ce chapitre, « la qualité du dispositif de contrôle, [et] non [...] des faits avérés de blanchiment ». Ce chapitre exige, comme premier axe de la diligence raisonnable envers tout prestataire, l’examen de « ses contrôles internes et opérationnels — y compris, le cas échéant, sa propre diligence sur ses sous-traitants (le « risque de quatrième partie ») ». Montrer que le recours par USAA à des sous-traitants « dont les qualifications n’avaient pas été vérifiées » est un cas d’école, révélé *a posteriori* par une sanction réglementaire, de ce que ce chapitre cherche précisément à prévenir *en amont* par la diligence raisonnable sur le risque de quatrième partie. Le cadre de ce chapitre, correctement appliqué par USAA avant l’engagement de ces sous-traitants, aurait-il suffi, à lui seul, à éviter la sanction — ou d’autres piliers du dispositif de ce chapitre (revue des contrôles internes, surveillance continue) auraient-ils également dû être mobilisés, compte tenu du fait que le constat du régulateur portait sur l’ensemble du programme de conformité LCB-FT et non sur le seul recours à des sous-traitants ?
- (b) Le chapitre 9 exige qu’une banque « développe des politiques et procédures AML/CFT à l’échelle du groupe, appliquées de manière cohérente », le partage d’information entre entités du groupe devant être « coordonné à l’échelle du groupe, pour permettre une surveillance croisée des relations à risque élevé » — un partage qui « se heurte toutefois dans certaines juridictions à des lois locales de protection des données perçues comme un obstacle », un défi que « le Comité de Bâle reconnaît explicitement comme plus prégnant pour la gestion du risque ML/FT que pour la plupart des autres processus de gestion des risques bancaires ». Ce chapitre traite un problème apparenté mais structurellement distinct : celui d’un prestataire étranger, non une filiale du même groupe, pour lequel « un contrat [...] devrait désigner explicitement la juridiction applicable en cas de litige » et pour lequel, si des données NPPI sont en jeu, « la responsabilité de leur divulgation incomb[e] conjointement à l’établissement et à son prestataire ». Comparer les deux dispositifs face à un même obstacle — des lois locales de protection des données freinant la circulation transfrontalière de l’information : pourquoi le chapitre 9 ne peut-il offrir, pour ce problème rencontré au sein d’un même groupe, qu’un principe de coordination interne (« la politique du groupe doit permettre à la succursale [...] d’adopter les exigences locales »), tandis que ce chapitre, confronté à un obstacle de même nature mais pour une relation avec un tiers externe, y répond par une clause contractuelle bilatérale de désignation de juridiction ? Ni l’un ni l’autre mécanisme ne peut faire disparaître la loi locale de protection des données elle-même : que résout alors précisément chacun des deux dispositifs, si aucun des deux ne peut agir sur la loi elle-même ?
- (c) Le chapitre 8 attribue la brèche Equifax à cinq faiblesses interconnectées, dont « l’absence

d'inventaire exhaustif des actifs informatiques », qui « a empêché les équipes de localiser et corriger Apache Struts dans le délai réglementaire de 48 heures », et « un certificat SSL expiré [qui] a empêché la surveillance du trafic chiffré pendant des mois, retardant la détection de l'intrusion jusqu'au 29 juillet — plus de trois mois après le début de l'attaque ». Ce chapitre exige, pour les relations d'externalisation les plus significatives, que l'établissement « évalue la qualité du dispositif de contrôle du prestataire — par exemple via un rapport d'audit type SOC 2 — et intègre les incidents de sécurité survenus chez le prestataire à sa propre surveillance », précisant qu'« aucun contrat [...] ne remplace une vérification active et continue ». Si Equifax avait été, non l'institution directement piratée, mais un prestataire fournissant un service externalisé d'évaluation de crédit à une banque cliente, montrer précisément comment l'application du dispositif de surveillance de ce chapitre (audit type SOC 2, indicateurs de performance mesurables, déclencheurs d'escalade) aurait dû amener la banque cliente à avoir une chance de détecter, indépendamment d'Equifax elle-même, au moins l'une des cinq faiblesses identifiées par le chapitre 8 — en particulier celle liée à l'inventaire des actifs ou celle liée au certificat SSL expiré. Une banque cliente exerçant un droit d'audit contractuel comme l'exige ce chapitre, mais ne l'exerçant qu'une fois tous les trois ans, aurait-elle pour autant satisfait à l'exigence de « vérification active et continue » posée par ce chapitre ?

- (d) Le chapitre 7, dans sa section consacrée aux interconnexions et aux tiers, indique que « les régulateurs attendent des institutions qu'elles se dotent d'un cadre d'externalisation approuvé par le conseil, incluant l'analyse préalable des risques (stratégique, de conformité, de sécurité, de continuité d'activité, de dépendance au prestataire, de concentration) et des clauses contractuelles garantissant un droit d'inspection et d'audit — parfois étendu directement aux autorités de supervision, comme en France, en Suisse et à Singapour », et décrit, pour les fournisseurs de cloud, des « sommets réglementaires » répondant à « la difficulté, pour un régulateur national isolé, d'exercer une supervision effective sur un fournisseur mondial ». Ce chapitre généralise ce dispositif, initialement présenté par le chapitre 7 pour le seul risque cyber et le cloud, à l'ensemble des formes d'externalisation, en le structurant en six piliers explicites (évaluation des risques, diligence raisonnable, clauses contractuelles, incitations de rémunération, surveillance continue, continuité d'activité). Montrer que les six catégories de risques citées par le chapitre 7 pour l'« analyse préalable des risques » (stratégique, de conformité, de sécurité, de continuité d'activité, de dépendance au prestataire, de concentration) recoupent largement, sans lui être identiques, les cinq catégories de risque posées par ce chapitre (conformité, concentration, réputationnel, pays, opérationnel) : identifier au moins une catégorie du chapitre 7 sans équivalent explicitement nommé chez ce chapitre, et au moins une catégorie de ce chapitre sans équivalent explicitement nommé chez le chapitre 7. Identifier ensuite deux éléments que ce chapitre détaille et que le chapitre 7 ne faisait qu'esquisser sans les nommer explicitement.

3 Applications en sciences économiques

Exercice 5 — Le risque de concentration des prestataires : mesurer l'exposition et vérifier la politique int

Une banque a externalisé cinq activités critiques, chacune confiée à un prestataire, pour une dépense annuelle d'externalisation donnée (en k€) :

Activité critique	Prestataire	Dépense annuelle (k€)
Hébergement cloud (IaaS)	Nimbus	1 200
Traitement des paiements (back-office)	Nimbus	950
Centre d'appels clientèle	Voxa	430
Surveillance cybersécurité (SOC externalisé)	Nimbus	610
Recouvrement de créances	Recoubank	260

La politique interne de gestion du risque de concentration de la banque fixe un plafond de 50 % de

la dépense totale d'externalisation critique par prestataire, et considère qu'un indice de Herfindahl-Hirschman (HHI, somme des carrés des parts de marché de chaque prestataire exprimées en pourcentage) supérieur à 3 000 signale une concentration excessive du portefeuille de prestataires.

- Calculer la dépense totale d'externalisation, la dépense totale confiée à chacun des trois prestataires (Nimbus, Voxa, Recoubank), et la part de chacun dans la dépense totale. Le plafond de 50 % par prestataire est-il respecté ?
- Calculer l'indice HHI du portefeuille de prestataires tel qu'il se présente initialement. Ce portefeuille est-il, au sens du seuil interne de 3 000, en situation de concentration excessive ?
- La banque envisage de retirer à Nimbus la surveillance cybersécurité (610 k€) pour la confier à un nouveau prestataire, SentinelSec, tiré de son vivier de prestataires alternatifs (cf. le cours sur la planification de la continuité). Recalculer la part de Nimbus dans la dépense totale et le nouvel indice HHI après cette diversification. Cette seule mesure suffit-elle à ramener la part de Nimbus sous le plafond de 50 % ? Commenter.
- Nimbus sous-traite lui-même 25 % du volume de travail lié à l'hébergement cloud (l'activité à 1 200 k€) à un sous-traitant étranger — un cas de « risque de quatrième partie » au sens du cours. Calculer le montant, en k€, de la dépense d'externalisation ainsi exposée à ce sous-traitant de rang deux, et sa part dans la dépense totale du portefeuille. En quoi la combinaison de ce risque de quatrième partie avec le risque pays (le sous-traitant étant situé à l'étranger) renforce-t-elle, selon le cours, la nécessité d'une clause contractuelle de juridiction applicable clairement désignée avec Nimbus lui-même ?

Exercice 6 — Défaillance d'un prestataire critique : surveillance, escalade et vivier de prestataires alternatifs

Une banque a externalisé son centre d'appels clientèle au prestataire Allo Assist. Elle suit deux indicateurs de performance mesurables sur quatre trimestres, avec les seuils suivants : taux de résolution au premier contact (seuil minimal : 85 %) et délai moyen de traitement (seuil maximal : 4,0 heures). Sa politique de surveillance déclenche une escalade dès qu'un indicateur franchit son seuil pendant deux trimestres consécutifs.

Indicateur	T1	T2	T3	T4
Taux de résolution au premier contact (%)	87	82	79	76
Délai moyen de traitement (heures)	3,6	4,3	5,1	5,8

- Pour chaque trimestre et chaque indicateur, indiquer s'il respecte ou franchit son seuil. À l'issue de quel trimestre le déclencheur d'escalade (deux franchissements consécutifs) se trouve-t-il activé pour chacun des deux indicateurs ?
- En admettant une tendance linéaire simple entre T1 et T4, calculer la pente trimestrielle de chaque indicateur, puis sa valeur projetée en T5 si aucune action corrective n'est engagée.
- La surveillance standard, trimestrielle, ne confirme un déclencheur d'escalade (deux trimestres consécutifs de franchissement) que 270 jours après le début effectif de la dégradation du service, survenu en tout début de T2 (jour 90). Une surveillance renforcée mensuelle, réservée aux prestataires montrant des signes de dégradation, aurait confirmé le même déclencheur dès le jour 150. Sachant que chaque jour de dégradation non corrigée coûte à la banque 800 € (compensations clients, traitement des réclamations), calculer la réduction du délai de détection (en jours) et l'économie ainsi permise par une surveillance mensuelle plutôt que trimestrielle.
- La banque évalue l'intérêt de maintenir, dans son plan de continuité, un vivier de deux prestataires alternatifs pré-qualifiés. Sans ce vivier, une défaillance complète d'Allo Assist imposerait une transition de 45 jours vers un nouveau prestataire choisi dans l'urgence ; avec le vivier, la transition ne prendrait que 10 jours. Chaque jour de transition coûte à la banque 12 000 € (interruption partielle de service). Le maintien du vivier coûte 18 000 € par an (qualification et réévaluation périodiques des deux prestataires alternatifs), et la probabilité qu'une défaillance complète d'Allo Assist survienne dans l'année est estimée à 8 %. Calculer le coût de transition par événement, puis le coût annuel attendu, avec et sans le vivier de prestataires alternatifs (le coût

avec vivier incluant son coût de maintien). Le maintien du vivier est-il justifié économiquement, et par quelle marge?